



CARBANAK

APT INTELLIGENCE REPORT

– Advanced Persistent Threat Analysis –

100+

BANKS COMPROMISED

\$1B+

USD STOLEN

40+

COUNTRIES HIT

2013

ACTIVE SINCE

ALSO KNOWN AS: ANUNAK | FIN7 | COBALT GROUP

THREAT LEVEL: CRITICAL



01 INTRODUCTION — WHAT IS CARBANAK?

Carbanak is a cybercriminal Advanced Persistent Threat (APT) group that targeted the global financial sector. It began as a small operation around 2013, evolving from the Carberp banking trojan. The group's goal was simple yet revolutionary: steal directly from banks instead of customers.

ORIGIN	Evolved from Carberp banking trojan source code (2013)
PRIMARY TARGET	Global financial sector — banks, not customers
OPERATING MODEL	Corporate structure with developers, testers, PMs, HR recruiters
PEAK ACTIVITY	2013 – 2018 (affiliate activity continues)
MOTIVATION	Financial theft, espionage, monetization of access

Unlike typical malware gangs, Carbanak operated like a corporate enterprise — with developers, testers, project managers, and even HR recruiters. It became a benchmark case in cybersecurity training, compliance, and red-team simulations worldwide.

02 HISTORICAL TIMELINE



03 ATTACK LIFECYCLE — STEP BY STEP

I. INITIAL ACCESS	Sends phishing emails disguised as legitimate bank notifications. Attachments exploit vulnerabilities in Microsoft Office or Adobe Reader.
II. EXECUTION	Installs Carbanak RAT (Remote Access Trojan). RAT connects to C2 servers via HTTPS or Google Apps Script.
III. PERSISTENCE	Creates Windows services and registry keys to survive reboots. Ensures long-term foothold inside the compromised network.



IV. PRIVILEGE ESCALATION	Uses Mimikatz to steal admin credentials. Gains domain-level access to move freely.
V. LATERAL MOVEMENT	Moves across internal networks using PsExec, RDP, and TeamViewer. Maps internal systems.
VI. IMPACT	Gains control of banking systems, executes fraudulent transactions, and triggers ATM cashouts.

04

APT INTELLIGENCE DATA MODEL

APT NAME	Carbanak / Anunak / FIN7 / Cobalt Group
ACTIVE PERIOD	2013 – 2018 (sporadic affiliate activity continues)
MOTIVATION	Financial theft, espionage, monetization of access
KNOWN OPERATORS	Eastern-European cybercriminal syndicates; arrests in Spain (2018)
VICTIM COUNTRIES	Russia, Ukraine, USA, UK, Germany, India
TARGET INDUSTRIES	Banking, retail, hospitality, financial services
C2 INFRASTRUCTURE	Encrypted C2 via Google Apps Script and compromised servers
BEHAVIORAL SHIFT	Carberp-based malware → modular Cobalt Strike beacons

MITRE ATT&CK TECHNIQUE MAPPING

TECHNIQUE ID	NAME / DESCRIPTION
T1566	Phishing — Initial access vector
T1059	Command Execution — PowerShell / batch scripts
T1071	C2 over HTTPS — Encrypted communications
T1027	Obfuscated Files/Scripts — Evasion
T1105	Remote File Copy — Tool staging

INDICATORS OF COMPROMISE (IOC)

[DOMAIN]	update-bank.com
[DOMAIN]	carbanak.org
[DOMAIN]	cobaltgroup.cc
[IP]	185.86.149.125
[IP]	91.220.131.65
[HASH]	b3a1d9f2e4c6... (Carbanak RAT sample)
[HASH]	f9c7a8b1d2... (Anunak dropper)
[MUTEX]	Global\CarbanakMutex

CARBANAK RAT

FAMILY NAME	Carbanak RAT
DISCOVERY	2014 by Kaspersky Lab during Anunak campaign
ORIGIN	Derived from Carberp source code; modularized for remote control
FILE EXTENSIONS	.cpl · .doc · .exe · .scr
ASSOCIATED GROUPS	FIN7, Cobalt Group
NETWORK INDICATORS	HTTPS C2, Google Apps Script, dynamic DNS
UNIQUE ARTIFACTS	Direct manipulation of banking software GUIs

TECHNICAL BEHAVIOR

CAPABILITY	DESCRIPTION
Keylogging	Records all keystrokes to harvest credentials and banking data.
Screen Capture	Takes periodic screenshots to map banking system interfaces.
Fileless Execution	Runs in memory via PowerShell and batch scripts — leaves minimal disk traces.
Persistence	Creates Windows registry keys and services to survive reboots.
C2 Communication	Connects via HTTPS; also abuses Google Apps Script for covert C2.

YARA DETECTION RULE (EXAMPLE)

```
rule Carbanak_RAT {
  meta:
    description = "Detects Carbanak RAT artifacts"
    author = "RedKross TI Platform"
    strings:
      $mutex = "Global\\CarbanakMutex"
      $str1 = { 43 61 72 62 61 6E 61 6B } // "Carbanak"
      $str2 = "update-bank.com"
    condition:
      any of them
}
```

CAMP ID	ACTOR	PERIOD	TARGET	KEY TTPs	NOTES
CAMP-001	Carbanak	2013–2015	Russia/Ukraine Banking	T1059, T1566	Initial Anunak heists
CAMP-002	FIN7	2016–2017	Global Finance/Retail	T1071, T1105	SWIFT fraud, ATM cashouts
CAMP-003	Cobalt Group	2018	EU/Asia Banking	T1027, T1059	Post-arrest resurgence



07

RANSOMWARE & AFFILIATE LINKS

Although Carbanak's primary focus was theft, its infrastructure later supported ransomware affiliates, extending its damage well beyond direct bank fraud.

ATTRIBUTE	DETAILS
Linked Families	Cobalt Strike · BitPaymer · Early Ryuk variants
Extortion Style	Data theft followed by ransom negotiation
Victim Sectors	Financial, retail, and hospitality
Infrastructure	Onion leak portals, encrypted communications, shared C2 servers

08

DEFENSIVE COUNTERMEASURES

DETECTION

- YARA rules for Carbanak mutexes and encrypted strings
- IOC correlation for known IPs and domains
- Monitor for Cobalt Strike beacons
- Behavioral analytics to detect lateral movement

PREVENTION

- Employee phishing awareness training
- Network segmentation and least-privilege access
- Patch Microsoft Office and Adobe Reader vulnerabilities promptly
- Segment critical financial systems (SWIFT, ATM networks)

RESPONSE

- Build SOC capable of detecting lateral movement and fileless malware
- Maintain IOC feeds and integrate with TI platform
- Enforce MFA on all administrative accounts
- Conduct regular red-team simulations using Carbanak's known TTPs

09

CYBERSECURITY IMPACT & STRATEGIC LESSONS

DOMAIN	IMPACT
Threat Intelligence	Carbanak campaigns are studied in IOC databases, MITRE ATT&CK mappings, and APT lifecycle models
Incident Response	Banks built SOCs capable of detecting lateral movement and fileless malware
Compliance	ISO 27001, PCI DSS, GDPR now emphasize insider monitoring and financial system hardening
Penetration Testing	Phishing, RAT deployment, and privilege escalation techniques replicated in ethical hacking labs
Fileless Malware	PowerShell and registry-based persistence influenced today's living-off-the-land attacks



DOMAIN	IMPACT
Cloud Abuse	Early use of Google Apps Script for C2 showed how attackers exploit legitimate cloud services
Global Cooperation	Europol, Interpol, national CERTs collaborated — set precedent for international cybercrime response

10 LIBRARY-FOLDER REVIEW WORKFLOW

STEP	ACTION
STEP 01	Assign folder name and review date
STEP 02	Divide 100 samples among 10 analysts
STEP 03	Extract filename, hash, and source for each file
STEP 04	Tag files: important / suspicious / reference-only
STEP 05	Write short analytical notes per file
STEP 06	Summarize folder-level findings
STEP 07	Flag duplicates or corrupted samples
STEP 08	Produce final evidence table and report

11 FINAL DELIVERABLES

◆ APT Profile Page	Carbanak lifecycle, aliases, and attribution data
◆ Campaign Timeline Dashboard	Visual evolution of Carbanak operations 2013–2018
◆ IOC Knowledge Base	Hashes, IPs, domains, mutexes — fully correlated
◆ Malware Family Pages	Carbanak RAT and related tools documented
◆ YARA Detection Library	Custom detection rules for Carbanak artifacts
◆ Research Notes & Evidence Tables	Folder-level analysis for all collected samples

REFERENCES FOR DEEP STUDY

- Kaspersky Lab: "Carbanak APT — The Great Bank Robbery"
- Europol Press Release (2018): Arrest of Carbanak leader in Spain
- MITRE ATT&CK: Techniques T1059, T1566, T1071, T1105
- Group-IB and FireEye Threat Reports on FIN7 / Carbanak



CONCLUSION

Carbanak is not just a hacker group — it is a cybersecurity milestone. It connects directly to threat intelligence platforms like RedKross, compliance frameworks such as ISO 27001 and PCI DSS, red-team training and penetration testing, and global cybercrime policy and defense strategy. Successor groups FIN7, TA505, and Cobalt Group continue to use Carbanak's playbook, proving its long-term influence on the threat landscape.